CYBERSECURITY • HANDS-ON LAB PROJECT

Phishing Simulation & Social Engineering Assessment

Kali Linux • Zphisher • Social-Engineer Toolkit (SET)

AUTHOR	DATE
Naveen Kumar S	18/10/2026
TOOLS	PROFILES
Zphisher • SET	LinkedIn • GitHub

Project scope
A learning-focused exploration of phishing-page simulation, email-based social-engineering workflows, associated risks, and defensive controls. Testing should be limited to authorized environments and synthetic data.

01 • Project Overview

This project explores how phishing and social-engineering techniques can exploit human trust and weaknesses in online security practices. Using Kali Linux, I examined Zphisher's phishing-page simulation workflow and reviewed email-related features in the Social-Engineer Toolkit (SET).

The aim was to understand how familiar-looking web pages and deceptive communications can influence user behavior—and how users and organizations can reduce these risks.

02 • Tools & Workflow

Zphisher — Phishing Page Simulation

I explored Zphisher's available page templates and its options for exposing a test page through different networking or tunneling methods. This illustrates why users should verify the full website address and domain before entering credentials.

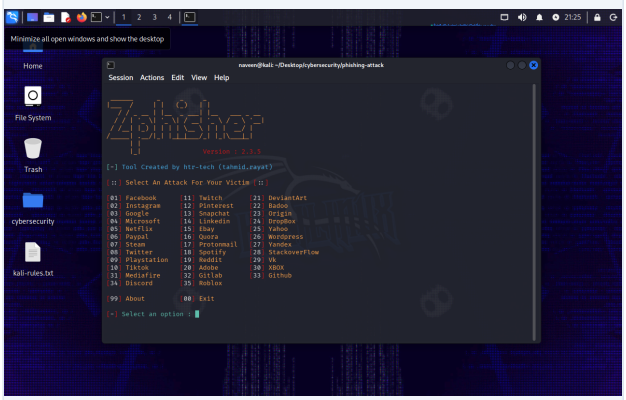


Figure 1. Zphisher template selection in Kali Linux.

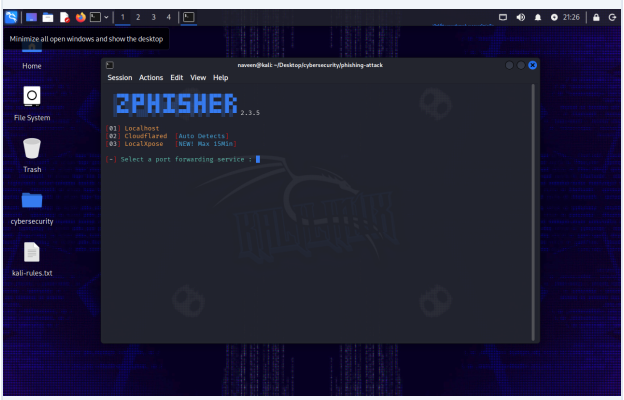


Figure 2. Zphisher networking / tunneling options.

Social-Engineer Toolkit (SET) — Email-Based Workflow

I reviewed SET's social-engineering menu and mass-emailer workflow to understand how email-based attack scenarios can be structured. Such workflows can be abused to distribute deceptive messages, making authorization, recipient consent, and safe test data essential.

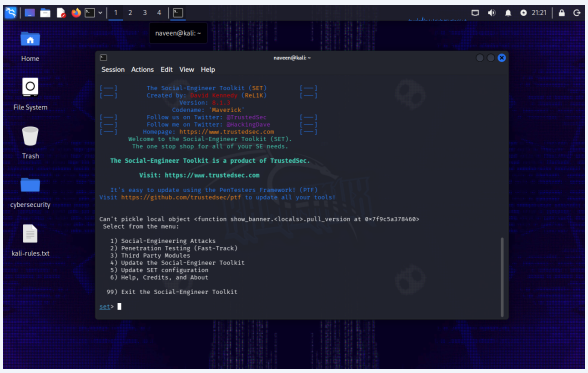


Figure 3. Social-Engineer Toolkit launched in Kali Linux.

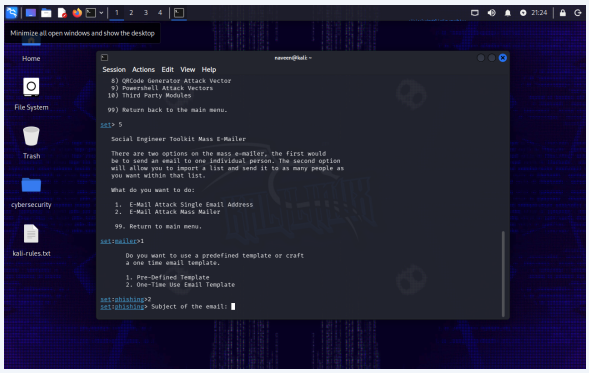


Figure 4. SET email-related workflow menu.

03 • Key Security Findings

Lookalike pages can create false trust.

Users may enter sensitive information without carefully checking a domain.

Email is a common social-engineering vector.

Deceptive messages can exploit urgency, curiosity, authority, or familiarity.

Mailbox exposure can increase impact.

An email account may contain private correspondence and password-reset messages.

Layered defense matters.

Technical controls work best alongside user awareness and incident response.

04 • Defensive Recommendations

- Enable multifactor authentication, preferably passkeys or phishing-resistant methods.
- Verify the full domain before entering credentials; avoid unexpected links.
- Use a password manager to reduce password reuse and help flag lookalike domains.
- Implement email authentication and filtering, including SPF, DKIM, and DMARC.
- Run authorized phishing-awareness exercises with clear scope and safe landing pages.
- Monitor unusual sign-ins; if exposure occurs, reset passwords, revoke sessions, and review account activity.

05 • Lessons Learned & Conclusion

This project strengthened my understanding of phishing simulation, email-based social engineering, human-factor risk, and layered security defenses. Phishing is both a technical and behavioral challenge; effective protection combines user awareness, strong authentication, email security, monitoring, and a clear reporting process.

Ethical testing & privacy
This project is intended for cybersecurity education and authorized assessment. Use controlled infrastructure, consenting participants, and synthetic credentials. Do not collect, retain, or publish real credentials or personal information without appropriate authorization.

NAVEEN KUMAR S
Cybersecurity Project Documentation
LinkedIn Profile
GitHub Profile